

What is Risk Identification?

Before we actually protect Phoenix we first need to figure out how dangerous each threat actually is. we already know what threats exist thanks to Rasanjana's STRIDE work but now we need to ask a simple question for each one how bad would it actually be if this threat actually happened?

To answer that I look at two things for each threat:

Likelihood → how likely is it that an attacker would actually try this?

- High → this is easy to do, commonly attempted and has actually happened in real Australian incidents before
- Medium → This is possible but needs more effort or specific conditions to pull off
- Low → This is technically complex or unlikely to happen in the Phoenix context

Impact → What would actually happen to Phoenix and the communities it protects if this worked?

- Critical → People could be directly harmed, the system could completely fail or the damage could be very hard to reverse
- High → Phoenix operations would be significantly disrupted but recovery is possible
- Medium → There would be noticeable problems but nothing catastrophic

When we put Likelihood and Impact together we get an **Overall Risk Rating**:

- **Critical** = Needs immediate attention → too serious to ignore
- **High** = Needs serious attention → significant risk to operations or community safety
- **Medium** = Needs monitoring → manageable but should not be ignored

Now lets go through every STRIDE threat and assign a risk rating.

Spoofing Risks

Spoofing is basically when an attacker pretends to be something or someone they are not a trusted data source, a real user or an official alert channel. for Phoenix this is really dangerous because the whole system depends on trusting what it receives and who is using it.

ST-01 → External Disaster Data APIs (BoM / CFA Feed)

Likelihood: **Medium** Spoofing the Bureau of Meteorology or CFA API needs significant technical capability but the 2019 Australia Early Warning Network attack showed that spoofing emergency

data systems has actually happened in Australia before so its not just a theoretical risk (Chakraborty et al., 2024).

Impact: **Critical** If Phoenix receives false disaster data it wont elevate its threat monitoring during a real bushfire or flood and communities will be left completely unprotected at the worst possible time.

Overall Risk: **Critical**

ST-02 → External Cyber Threat & Scam Feeds (Scamwatch / ASD)

Likelihood: **Medium** Open source threat intelligence feeds are generally less protected than government APIs which makes them a more realistic target for spoofing attacks.

Impact: **Critical** The AI model makes all its threat classifications based on this data so if that data is fake the model will classify real scams as safe and communities will never get warnings about active threats targeting them.

Overall Risk: **Critical**

ST-03 → DMT User Login Portal

Likelihood: **High** Phishing attacks against staff during high pressure situations like disasters are one of the most common attack methods in cybersecurity. DMT staff working during a disaster are way more vulnerable than they would be on a normal day.

Impact: **Critical** A compromised DMT account gives an attacker direct control over the most powerful functions in Phoenix — approving public alerts, suppressing genuine warnings and changing how the AI model works.

Overall Risk: **Critical**

Real-world evidence: In 2019 stolen credentials were used to impersonate an authorised operator and send fake emergency alerts to thousands of Queensland residents through Australia's Early Warning Network (Chakraborty et al., 2024).

ST-04 → Alert System (Send Secure Alert / API Dispatch)

Likelihood: **Medium** Spoofing Phoenix's official alert channel requires OAuth token theft or an SMS gateway compromise — both are achievable but need significant effort.

Impact: **Critical** Fake official emergency alerts sent to communities during a disaster could cause mass panic, trigger unnecessary evacuations and permanently destroy public trust in official emergency communications.

Overall Risk: **Critical**

Real-world evidence: In 2025 fraudulent SMS messages impersonating Centrelink and the Queensland Premier's disaster relief appeal were sent to disaster affected communities appearing to come from legitimate government sources (Scamwatch, 2020).

ST-05 → Community Feedback Module (Third-Party Report Submissions)

Likelihood: **Medium** The feedback module is open facing and while official agency verification exists it has limitations. impersonating an official agency like Victoria Police requires effort but is achievable.

Impact: **High** False submissions from an impersonated agency carry the highest confidence weighting in the retraining pipeline which systematically shifts how the AI model thinks about threats in the attackers favour.

Overall Risk: **High**

Tampering Risks

Tampering is when an attacker modifies data without authorisation. in Phoenix every component depends on data being accurate so tampering at any point in the pipeline can corrupt everything that comes after it.

ST-06 → External Disaster Data (BoM Feed → Data in Transit)

Likelihood: **Medium** Man in the middle attacks against API data feeds are well documented and technically achievable particularly if TLS certificate verification is not properly enforced.

Impact: **Critical** If an attacker downgrades a real disaster severity rating before it reaches Phoenix the system will never elevate its threat monitoring for that event and genuine scam campaigns targeting disaster victims will go completely undetected.

Overall Risk: **Critical**

ST-07 → Data Validation (Schema Validation Gate)

Likelihood: **Medium** So basically if someone figures out how the validation logic works they can craft data that looks perfectly fine on the outside but is actually malicious on the inside. its like putting something dangerous in a package that passes the security check because it looks like a normal parcel.

Impact: **High** Once that malicious data gets through the validation gate it just flows straight into the pipeline and reaches the AI model and Correlation Engine without anyone knowing something dodgy got through.

Overall Risk: **High**

ST-08 → Stream Processing (Kafka / Firebase / APIs)

Likelihood: **Medium** If the Kafka broker has not been properly secured like if default settings were never changed or a service account got compromised someone could get access and start injecting their own data into the stream after the validation has already run and passed everything.

Impact: **Critical** The scary part is that this happens after validation so the system has no reason to be suspicious. attacker controlled data just flows through to the AI model and Correlation Engine like it is completely normal and risk scores can be quietly manipulated without triggering anything.

Overall Risk: **Critical**

ST-09 → AI Model Processing (Threat Classification / Scam Detection)

Likelihood: **High** You dont even need to get inside Phoenix to do this. an attacker can just keep sending different inputs and watching how the model responds to slowly figure out where its weak spots are. its called black box probing and its a well known technique that pretty much anyone with enough patience can do.

Impact: **Critical** Once an attacker knows where the weak spots are they can craft scam content that consistently gets classified as safe. Phoenix then never alerts anyone about those scams and disaster affected communities get targeted without any warning going out.

Overall Risk: **Critical**

ST-10 → Scam DB / Cyber Threat DB (Database Records)

Likelihood: **Medium** SQL injection and insider access are both realistic attack vectors against Phoenix's databases and both have been used successfully against Australian organisations before.

Impact: **Critical** Corrupted database records degrade AI model detection accuracy across every threat category simultaneously because the model learns from those records every time it is retrained.

Overall Risk: **Critical**

Real-world evidence: The Fire Rescue Victoria ransomware attack demonstrated that Australian emergency services databases are actively targeted and that the consequences of database compromise can persist for months (Chirgwin, 2023).

ST-11 → Correlation Engine (Cross-refer Scams & Disasters / Risk Scoring)

Likelihood: **Medium** Injecting false timestamp or geolocation metadata into the data pipeline requires access but is technically achievable through a compromised upstream component.

Impact: **Critical** Genuine disaster correlated cyber threats receive falsely low risk scores and are never escalated to DMT review. community alerts are silently suppressed during active attacks without anyone realising.

Overall Risk: **Critical**

ST-12 → Model Retraining (Feedback Collection Loop)

Likelihood: **High** The community feedback module is open facing and coordinated adversarial feedback submissions do not require any technical sophistication just organisation and persistence.

Impact: **Critical** Every retraining cycle makes the AI model worse rather than better. Phoenix's ability to detect disaster scams is systematically degraded over time through the very mechanism that was designed to improve it.

Overall Risk: **Critical**

Repudiation Risks

Repudiation is when someone denies having taken an action and there is no evidence to prove otherwise. for Phoenix this is serious because the system needs to be accountable to communities, emergency services and government agencies for every alert it sends and every decision it makes.

ST-13 → DMT Review (Critical Cases — Alert Approval)

Likelihood: **Medium** A malicious DMT Reviewer deliberately suppressing alerts is an insider threat scenario. it requires existing access but no additional technical capability beyond what they already have.

Impact: **High** Without an immutable audit trail there is no accountability for critical alert suppression decisions. genuine threats go unaddressed during active disasters with no way to trace who was responsible.

Overall Risk: **High**

ST-14 → Alert System (Alert Dispatch Log)

Likelihood: **Medium** Alert log tampering requires system level access but is a common post compromise action by attackers trying to cover their tracks.

Impact: **High** Communities and agencies cannot verify whether a critical warning was sent or suppressed. post disaster investigations cannot establish what actually happened or who was responsible.

Overall Risk: **High**

ST-15 → Scam DB / Cyber Threat DB (Database Access Log)

Likelihood: **Medium** Deleting or altering database logs after a breach is standard practice for attackers trying to avoid detection and is achievable by anyone with database level access.

Impact: **High** No ability to determine which records were changed, when they were changed or by whom completely undermining post incident investigation and any hope of accountability.

Overall Risk: **High**

ST-16 → Data Validation (Validation Decision Log)

Likelihood: **Low** Honestly to exploit this one you would need to know quite specifically how Phoenix logs its validation decisions which is pretty niche knowledge. most attackers would have bigger and easier targets to go after first.

Impact: **Medium** If something does go wrong with the validation layer and there are no logs it becomes harder to trace exactly where the problem came from. its annoying for the investigation team but it doesn't directly cause Phoenix to fail or communities to be harmed.

Overall Risk: **Medium**

Information Disclosure Risks

Information disclosure is when sensitive data is exposed to people who should not have access to it. for Phoenix this is especially serious because the system handles personal data belonging to some of Australia's most vulnerable people disaster victims.

ST-17 → Scam DB / Cyber Threat DB (Personal Data of Disaster Victims)

Likelihood: **Medium** SQL injection and misconfigured access controls are among the most common attack vectors against database systems and are well within the capability of organised cybercrime groups.

Impact: **Critical** Privacy violation and identity theft of vulnerable disaster affected individuals causes serious and lasting real world harm. it would also completely destroy community trust in Phoenix and government disaster management systems.

Overall Risk: **Critical**

Real-world evidence: In 2025 personal data of 3,000 NSW flood victims from the Resilient Homes Program was exposed after a contractor uploaded it to ChatGPT showing exactly how serious careless data handling is in disaster context systems.

ST-18 → AI Model Processing (Model Inversion / Membership Inference)

Likelihood: **Medium** Model inversion attacks require systematic querying of the model but do not need direct access to its internals making them realistic for a technically capable adversary.

Impact: **High** An attacker who learns which scam patterns Phoenix is trained to detect can design content that precisely avoids those patterns turning information disclosure into a precursor for a much more damaging model evasion campaign.

Overall Risk: **High**

ST-19 → Stream Processing (Firebase Community Interface)

Likelihood: **Medium** Firebase misconfiguration is one of the most commonly reported security issues in real world systems and is a well documented vulnerability class.

Impact: **High** Personal data of community members submitting threat reports during a disaster gets exposed to unauthorised parties discouraging future community engagement and violating privacy obligations at exactly the wrong time.

Overall Risk: **High**

Denial of Service Risks

Denial of service is when an attacker prevents legitimate users or systems from accessing resources they need. for Phoenix this is uniquely dangerous because these attacks are most effective during disaster events exactly when Phoenix needs to be most available.

ST-20 → Alert System (Alert Delivery API Endpoints)

Likelihood: **High** DDoS attacks against alert delivery APIs are among the most commonly executed attacks in cybersecurity and require minimal technical sophistication to launch.

Impact: **Critical** Community members and emergency services do not receive critical safety warnings during the most dangerous period of a disaster event. this is the worst possible outcome for a system whose entire purpose is to deliver those warnings.

Overall Risk: **Critical**

Real-world evidence: DDoS attacks targeting emergency response websites during active crisis events were documented in 2024 confirming that threat actors deliberately time these attacks to coincide with disasters.

ST-21 → Stream Processing (Kafka / Firebase)

Likelihood: **Medium** Flooding Kafka topics requires the ability to generate high message volumes but is achievable through automated tooling that is widely available.

Impact: **Critical** Phoenix loses its entire real time threat detection capability at precisely the moment disaster context cyber threats are at their peak leaving communities completely unmonitored.

Overall Risk: **Critical**

ST-22 → External Data Fetch Endpoints (BoM / Scamwatch / ASD)

Likelihood: **High** DoS attacks against external API endpoints are among the simplest and most commonly executed attacks in cybersecurity requiring minimal technical skill to launch.

Impact: **Critical** Phoenix operates without any live disaster or threat intelligence. risk scoring and alert generation rely on stale cached data during an active disaster completely undermining the system's real time value.

Overall Risk: **Critical**

ST-23 → Failure to Fetch / Retry Mechanism

Likelihood: **Low** To actually pull this off you would need to know specifically how Phoenix's retry logic works and trigger it in a very particular way to cause a resource exhaustion loop. its a pretty niche attack that most adversaries would not bother with when there are easier options available.

Impact: **Medium** If it's work it would slow things down and consume system resources during a disaster but other parts of Phoenix can keep running independently so it would not completely take the system down.

Overall Risk: **Medium**

ST-24 → Scam DB / Cyber Threat DB (Ransomware Encryption)

Likelihood: **Medium** Ransomware needs initial access to the system first but we already know from the Fire Rescue Victoria attack in 2022 that Australian emergency services are actively being targeted by organised cybercrime groups who have the capability and motivation to do exactly this (Chirgwin, 2023).

Impact: **Critical** If the databases get encrypted Phoenix basically loses all its threat intelligence overnight. the AI model has nothing to work with and the whole detection pipeline stops. and because it happens during a disaster the pressure to just pay the ransom and get back online quickly is enormous.

Overall Risk: **Critical**

Elevation of Privilege Risks

Elevation of privilege is when an attacker or insider gains access beyond what they are actually authorised to do. in Phoenix this is particularly dangerous because the system's most powerful functions approving alerts and configuring AI models are protected by role based access controls that could be bypassed or misconfigured.

ST-25 → DMT User Login (Authentication / Session Management)

Likelihood: **Medium** Things like session fixation or token manipulation do need some level of existing access to pull off but they are well documented attacks and if someone has already managed to get a low level account inside Phoenix they have a realistic path to escalating from there.

Impact: **Critical** This is one of the worst case scenarios for Phoenix. if someone with a basic read only account can elevate themselves to administrator level they suddenly have access to everything approving alerts, changing model settings, managing data sources all through what looks like a legitimate account doing normal things.

Overall Risk: **Critical**

ST-26 → Role-Based Access Control (RBAC Configuration)

Likelihood: **Medium** RBAC misconfiguration is one of the most common and well documented vulnerabilities in complex access control systems and is often introduced accidentally during routine system updates.

Impact: **Critical** An insider with inflated permissions can suppress genuine alerts, alter model parameters, introduce corrupted feedback and exfiltrate threat intelligence all using their own legitimate credentials with minimal detection risk.

Overall Risk: **Critical**

ST-27 → Stream Processing (Kafka Broker / Firebase Admin)

Likelihood: **Medium** Exploiting Kafka authentication configuration or Firebase admin SDK vulnerabilities requires technical knowledge but misconfiguration in these systems is a well documented real world problem.

Impact: **Critical** An attacker with elevated broker access can inject malicious data across all Kafka topics simultaneously effectively becoming a trusted internal component of the pipeline and corrupting every downstream process at once.

Overall Risk: **Critical**

Risk Summary Table

ID	Component	STRIDE	Likelihood	Impact	Overall Risk
ST-01	External Disaster Data APIs	Spoofing	Medium	Critical	Critical
ST-02	External Cyber Threat Feeds	Spoofing	Medium	Critical	Critical
ST-03	DMT User Login	Spoofing	High	Critical	Critical
ST-04	Alert System API	Spoofing	Medium	Critical	Critical
ST-05	Community Feedback Module	Spoofing	Medium	High	High
ST-06	BoM Feed Data in Transit	Tampering	Medium	Critical	Critical
ST-07	Data Validation Gate	Tampering	Medium	High	High
ST-08	Stream Processing Kafka	Tampering	Medium	Critical	Critical
ST-09	AI Model Processing	Tampering	High	Critical	Critical
ST-10	Scam DB / Cyber Threat DB	Tampering	Medium	Critical	Critical
ST-11	Correlation Engine	Tampering	Medium	Critical	Critical
ST-12	Model Retraining Loop	Tampering	High	Critical	Critical

ID	Component	STRIDE	Likelihood	Impact	Overall Risk
ST-13	DMT Review	Repudiation	Medium	High	High
ST-14	Alert Dispatch Log	Repudiation	Medium	High	High
ST-15	Database Access Log	Repudiation	Medium	High	High
ST-16	Data Validation Log	Repudiation	Low	Medium	Medium
ST-17	Scam DB Personal Data	Information Disclosure	Medium	Critical	Critical
ST-18	AI Model Inversion	Information Disclosure	Medium	High	High
ST-19	Firebase Community Interface	Information Disclosure	Medium	High	High
ST-20	Alert Delivery API	Denial of Service	High	Critical	Critical
ST-21	Stream Processing Kafka	Denial of Service	Medium	Critical	Critical
ST-22	External Data Fetch Endpoints	Denial of Service	High	Critical	Critical
ST-23	Retry Mechanism	Denial of Service	Low	Medium	Medium
ST-24	Database Ransomware	Denial of Service	Medium	Critical	Critical
ST-25	DMT Login Session Management	Elevation of Privilege	Medium	Critical	Critical
ST-26	RBAC Configuration	Elevation of Privilege	Medium	Critical	Critical
ST-27	Kafka Broker Firebase Admin	Elevation of Privilege	Medium	Critical	Critical

Risk Summary by STRIDE Category

STRIDE Category	Total Threats	Critical	High	Medium
Spoofing	5	4	1	0
Tampering	7	6	1	0
Repudiation	4	0	3	1
Information Disclosure	3	1	2	0
Denial of Service	5	4	0	1
Elevation of Privilege	3	3	0	0
Total	27	18	7	2

What This Risk Identification Tells Us About Phoenix

So out of 27 STRIDE threats identified across Phoenix 18 are rated Critical, 7 are rated High and only 2 are rated Medium. that basically tells us that almost every part of Phoenix carries serious security risk and there are very few areas where the team can afford to relax.

The Tampering and Spoofing categories have the highest concentration of Critical risks which means protecting the integrity of Phoenix's data and the authenticity of its users and outputs needs to be the team's top priority. the fact that Denial of Service also has 4 Critical ratings is particularly important for Phoenix because these attacks are most effective during the exact disaster conditions when Phoenix needs to be most available and most reliable.

Knowing these risk levels is what allows the team to make smart decisions about where to focus security investment not spreading effort equally across everything but putting the most serious controls on the most serious risks. that is exactly what risk identification is for.

Threat Model Table

What is a Threat Model Table?

A threat model table is basically the final destination of everything the cybersecurity team has done so far. Think of it like this throughout CY004 and CY005 we have been building pieces of a puzzle. Rasanjana identified the STRIDE threats. We identified the risks. Earlier in CY004 we identified the attackers, the vulnerabilities and the attacks. Now this table puts all of those pieces together into one single document that anyone a developer, a project manager, a stakeholder, or a new team member who has never seen the project before, can open and immediately understand what threats Phoenix faces, how serious they are and what weakness makes each one possible.

This is why a threat model table is so valuable in real cybersecurity work. Instead of reading through multiple documents and trying to connect the dots yourself the table does that work for you. Every row tells a complete story about one threat, what category it belongs to, which part of Phoenix it targets, what the attacker actually does, which vulnerability makes it possible and how dangerous it is overall.

How to Read This Table

Each row in the threat model table contains six pieces of information:

Threat ID → this is the reference number from Rasanjana's STRIDE analysis. ST stands for STRIDE Threat so ST-01 is STRIDE Threat number one and so on up to ST-27.

STRIDE Category → this tells you what type of threat it is. Is the attacker pretending to be someone they are not (Spoofing)? Are they changing data they should not touch (Tampering)? Are they trying to avoid being held accountable (Repudiation)? Are they stealing sensitive information (Information

Disclosure)? Are they trying to shut the system down (Denial of Service)? Or are they trying to get more access than they are allowed (Elevation of Privilege)?

Component Targeted → this tells you exactly which part of the Phoenix system the attacker is going after.

Threat Description → this explains in plain language what the attacker actually does to carry out this threat.

Vulnerability Exploited → this is the specific weakness in Phoenix that makes this threat possible. This connects directly back to the vulnerabilities we identified in CY004.

Risk Rating → this is the overall risk level we assigned during the Identify Risks task. Critical means it needs immediate attention. High means it needs serious attention. Medium means it needs monitoring.

Phoenix Complete Threat Model Table

Threat ID	STRIDE Category	Component Targeted	Threat Description	Vulnerability Exploited	Risk Rating
ST-01	Spoofing	External Disaster Data APIs	Attacker uses DNS spoofing or a fake TLS certificate to impersonate the BoM API and feed Phoenix completely false disaster event data as if it were coming from a legitimate official source	V1 — No continuous check on feed content after authentication	Critical
ST-02	Spoofing	External Cyber Threat & Scam Feeds	Attacker impersonates Scamwatch or ASD using a spoofed API endpoint causing Phoenix to ingest attacker-controlled false threat intelligence as if it were verified official data	V1 — No continuous check on feed content after authentication	Critical
ST-03	Spoofing	DMT User Login Portal	Attacker uses stolen, phished or brute-forced credentials to impersonate a legitimate DMT analyst and gain full authenticated access to Phoenix's alert approval and model configuration functions	V5 — DMT staff more vulnerable during disasters	Critical
ST-04	Spoofing	Alert System API	Attacker impersonates Phoenix's official alert delivery channel through SMS gateway compromise or OAuth token theft	V18 — Phoenix cannot control alerts after they leave	Critical

Threat ID	STRIDE Category	Component Targeted	Threat Description	Vulnerability Exploited	Risk Rating
			to send fake verified emergency alerts directly to communities and agencies		
ST-05	Spoofing	Community Feedback Module	Attacker impersonates an official agency like Victoria Police or the CFA to submit false high-confidence threat confirmations that carry maximum weight in the model retraining pipeline	V20 — Anyone can submit feedback with no deep content check	High
ST-06	Tampering	External Disaster Data Feed	Attacker intercepts the BoM disaster feed in transit using a man-in-the-middle attack and modifies hazard severity ratings — for example downgrading an extreme bushfire to low — before the data reaches Phoenix	V1 — No continuous check on feed content after authentication	Critical
ST-07	Tampering	Data Validation Gate	Attacker crafts malformed payloads that exploit edge cases in the schema validation logic passing through undetected and carrying malicious content directly into the processing pipeline	V2 — No detection of unusual patterns in incoming data	High
ST-08	Tampering	Stream Processing Kafka	Attacker gains Kafka broker access through a compromised service account or network misconfiguration and injects malicious messages directly into Kafka topics after the Data Validation component has already cleared the data	V16 — Kafka broker could be accessed by unauthorised users	Critical
ST-09	Tampering	AI Model Processing	Attacker uses systematic black-box probing to map Phoenix's threat classification model decision boundaries and crafts scam content specifically designed to be consistently misclassified as safe and benign	V13 — AI models can be fooled by carefully crafted content	Critical

Threat ID	STRIDE Category	Component Targeted	Threat Description	Vulnerability Exploited	Risk Rating
ST-10	Tampering	Scam DB / Cyber Threat DB	Attacker exploits a SQL injection vulnerability or insider access to directly modify stored scam records and threat intelligence entries in the databases corrupting the historical data the AI model uses for every classification and retraining cycle	V9 — Malicious code could reach the database layer	Critical
ST-11	Tampering	Correlation Engine	Attacker injects carefully crafted false timestamp or geolocation metadata into the Correlation Engine's data feeds causing genuine disaster-correlated threats to produce falsely low risk scores and never reach DMT review	V2 — No detection of unusual patterns in incoming data	Critical
ST-12	Tampering	Model Retraining Loop	Attacker coordinates a large volume of adversarially crafted feedback submissions timed to arrive immediately before a scheduled model retraining cycle to maximise corruption of the next retrained model version	V21 — Quality filter on feedback is not foolproof	Critical
ST-13	Repudiation	DMT Review	Malicious DMT reviewer deliberately classifies a genuine high-risk threat as a false positive to suppress a public alert and then denies ever having seen or actioned the threat with no immutable audit trail to prove otherwise	V8 — Legitimate users can cause harm without triggering alerts	High
ST-14	Repudiation	Alert Dispatch Log	Attacker or insider who suppressed a genuine alert or issued a false one claims that no alert was ever sent or received with no tamper-evident delivery log in place to verify what actually happened	V10 — No permanent record of what happened to the data	High
ST-15	Repudiation	Database Access Log	Insider or attacker who modified or deleted database records also	V10 — No permanent	High

Threat ID	STRIDE Category	Component Targeted	Threat Description	Vulnerability Exploited	Risk Rating
			alters or completely deletes the database access logs to erase all evidence of the intrusion making forensic investigation impossible	record of what happened to the data	
ST-16	Repudiation	Data Validation Log	No persistent record is maintained of which data packets passed or failed validation so after an incident there is no way to determine whether malicious data entered the pipeline through a validation bypass or through a legitimate source	V2 — No detection of unusual patterns in incoming data	Medium
ST-17	Information Disclosure	Scam DB / Cyber Threat DB	Attacker exploits a SQL injection vulnerability or misconfigured access control to extract personal records of disaster victims — including names, addresses, phone numbers and health information — stored in the Phoenix databases	V9 — Malicious code could reach the database layer	Critical
ST-18	Information Disclosure	AI Model Processing	Attacker repeatedly queries Phoenix's AI model with carefully chosen inputs and analyses the output confidence scores to reconstruct which scam patterns and threat indicators the model was trained to detect — enabling precise future evasion	V13 — AI models can be fooled by carefully crafted content	High
ST-19	Information Disclosure	Firebase Community Interface	Misconfigured Firebase security rules expose community feedback records — including contact details, location data and submitted threat reports of disaster-affected residents — to unauthorised external read access	V20 — Anyone can submit feedback with no deep content check	High
ST-20	Denial of Service	Alert Delivery API	Attacker floods the Phoenix alert delivery API with a high volume of requests during an active disaster exhausting rate limits	V3 — Single point of failure on external API connections	Critical

Threat ID	STRIDE Category	Component Targeted	Threat Description	Vulnerability Exploited	Risk Rating
			and silently blocking all genuine alert commands from being processed and delivered to communities		
ST-21	Denial of Service	Stream Processing Kafka	Attacker floods Apache Kafka topics with massive message volumes to exhaust broker capacity — particularly effective during a disaster when data volumes are already elevated — causing legitimate message processing to slow dramatically or halt entirely	V16 — Kafka broker could be accessed by unauthorised users	Critical
ST-22	Denial of Service	External Data Fetch Endpoints	Attacker launches a denial-of-service attack against the BoM, Scamwatch or ASD API endpoints that Phoenix depends on for real-time data taking those feeds completely offline and creating dangerous monitoring blind spots during an active disaster	V3 — Single point of failure on external API connections	Critical
ST-23	Denial of Service	Retry Mechanism	Attacker deliberately triggers repeated data fetch failures causing Phoenix's retry mechanism to enter a continuous loop that exhausts system CPU and memory resources creating a self-inflicted denial of service through the system's own resilience mechanism	V3 — Single point of failure on external API connections	Medium
ST-24	Denial of Service	Scam DB / Cyber Threat DB	Organised cybercrime group deploys ransomware that encrypts the Scam DB and Cyber Threat DB rendering all historical threat intelligence completely inaccessible and halting AI model processing and Correlation Engine operations entirely	V11 — Backups could be wiped out along with primary data	Critical
ST-25	Elevation of Privilege	DMT User Login	Attacker who has compromised a Read-Only Analyst account	V6 — Wrong permission	Critical

Threat ID	STRIDE Category	Component Targeted	Threat Description	Vulnerability Exploited	Risk Rating
			exploits session fixation, JWT token manipulation or RBAC misconfiguration to escalate their access to DMT Reviewer or System Administrator level without any valid authorisation	settings could give too much access	
ST-26	Elevation of Privilege	RBAC Configuration	Misconfigured or overly permissive RBAC policy grants users access beyond their authorised role scope — for example a DMT Reviewer gaining System Administrator permissions — or allows an insider to self-assign elevated privileges without triggering any security alert	V6 — Wrong permission settings could give too much access	Critical
ST-27	Elevation of Privilege	Kafka Broker / Firebase Admin	Attacker exploits a vulnerability in Kafka's authentication configuration or a misconfigured Firebase admin SDK to gain producer or admin-level access to the message broker beyond their authorised consumer-only role enabling them to inject or read unrestricted message traffic	V16 — Kafka broker could be accessed by unauthorised users	Critical

Threat Count by STRIDE Category

STRIDE Category	Total Threats	Critical	High	Medium
Spoofing	5	4	1	0
Tampering	7	6	1	0
Repudiation	4	0	3	1
Information Disclosure	3	1	2	0
Denial of Service	5	4	0	1
Elevation of Privilege	3	3	0	0
Total	27	18	7	2

Most Targeted Components in Phoenix

Component	Number of Threats Targeting It
Scam DB / Cyber Threat DB	5
Stream Processing Kafka	4
External Data APIs	3
DMT User Login	3
Alert System API	3
AI Model Processing	3
Data Validation	2
Community Feedback Module	2
Correlation Engine	1
Model Retraining Loop	1

What This Threat Model Table Tells Us About Phoenix

Looking at this completed table as a whole there are three things that really stand out and that the team needs to pay attention to.

The databases are the most targeted part of the system. The Scam DB and Cyber Threat DB appear in 5 separate threat rows which is more than any other component. This makes complete sense

When you think about what those databases actually do they are Phoenix's memory. Every classification the AI model makes, every risk score the Correlation Engine produces and every retraining cycle the system runs depends entirely on the integrity of those records. If the databases are corrupted, encrypted or exfiltrated the entire system loses its intelligence foundation simultaneously.

Tampering is the most dangerous threat category. With 7 threats and 6 of them rated Critical the Tampering category represents the greatest concentration of risk across the Phoenix architecture. This tells the team that protecting the integrity of data at every stage of the pipeline from the moment it enters the system at the external feeds all the way through to the model retraining loop needs to be the highest priority security investment.

18 out of 27 threats are rated Critical. This is the most important number in the entire table. It means that the overwhelming majority of threats Phoenix faces are not theoretical edge cases they are serious, realistic risks that need genuine security controls in place before the system goes live. The threat model table is what gives the team the evidence to communicate that reality clearly to project stakeholders and to justify the security investment that Phoenix genuinely requires.

REFERENCES

Azambuja, A. J. G., Plesker, C., Schützer, K., Anderl, R., Schleich, B., & Almeida, V. R. (2023). Artificial intelligence-based cyber security in the context of Industry 4.0 — A survey. *Electronics*, 12(8).

<https://doi.org/10.3390/electronics12081920>

Chakraborty, S., Mombeshora, E. M., Clark, K. P., & Mbavarira, T. S. (2024). Understanding of cyber-attack vulnerabilities during natural disasters and discussing a cyber-attack resiliency framework. In *SoutheastCon 2024*. <https://doi.org/10.1109/SoutheastCon52093.2024.10500233>

Chirgwin, R. (2023). *Fire Rescue Victoria still hampered by December 2022 cyber attack*. iNews.

<https://www.itnews.com.au/news/fire-rescue-victoria-still-hampered-by-december2022-cyber-attack-597024>

Hunt, K., Agarwal, P., & Zhuang, J. (2022). Monitoring misinformation on Twitter during crisis events: A machine learning approach. *Risk Analysis*, 42(8), 1728–1748. <https://doi.org/10.1111/risa.13634>

Microsoft. (2024). *STRIDE threat model*. Microsoft Security Documentation.

<https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats>

Scamwatch. (2020). *Bushfires and scams*. Australian Competition and Consumer Commission.

<https://www.scamwatch.gov.au/about-us/news-and-alerts/bushfires-and-scams-0>

Spyros, A., Koritsas, I., Papoutsis, A., Panagiotou, P., Chatzakou, D., Kavallieros, D., Tsikrika, T., Vrochidis, S., & Kompatsiaris, I. (2025). AI-based holistic framework for cyber threat intelligence management. *IEEE Access*, 13, 20820–20846. <https://doi.org/10.1109/ACCESS.2025.3533084>